

OWASP Top 10

Security Misconfiguration

BIG school

BIGSEIO

GENERAMOS
NEGOCIO

Security Misconfiguration

Índice

- Introducción
- ¿Qué significa "Security Misconfiguration"?
- ¿Por qué ocurre esta vulnerabilidad?
- Ejemplos reales y típicos
- ¿Qué puede hacer un atacante si explota esto?
- ¿Cómo detectarlo?
- ¿Cómo prevenirlo?
- ¿Cómo mitigar si ya estás afectado?
- Checklist operativo rápido
- Conclusiones

Security Misconfiguration

BIG school

BIGSEIO

GENERAMOS
NEGOCIO

Introducción

- Categoría A02 en OWASP Top 10:2025
- Errores de instalación, configuración y mantenimiento
- Sistemas inseguros por defecto o por ajustes olvidados
- Objetivo: detectar, prevenir y endurecer entornos de forma automática

¿Qué significa "Security Misconfiguration"?

configuraciones que permiten accesos no autorizados

- No es bug de código: el entorno o sus settings facilitan el abuso
- Defaults no cambiados, políticas ausentes o permisos excesivos
- La configuración es parte del producto: si es insegura, nace vulnerable

¿Por qué ocurre esta vulnerabilidad?

- Defaults inseguros y credenciales sin cambiar
- Exposición involuntaria de puertos, endpoints o directorios
- Cabeceras de seguridad ausentes o CORS mal configurado
- Configs inconsistentes entre entornos (dev/staging/prod)
- Políticas de actualización o parcheo deshabilitadas
- Logs/errores que exponen stack traces o datos sensibles

Ejemplos reales y típicos

- Bases de datos con credenciales por defecto accesibles en internet
- Buckets S3/GCS públicos con backups o datos sensibles
- Paneles admin sin autenticación o en rutas comunes
- Mensajes de error verbosos en producción (stack traces, variables)
- Headers faltantes (HSTS, CSP) o Access-Control-Allow-Origin: *
- Imágenes Docker con herramientas de debug o CVEs sin parchear

¿Qué puede hacer un atacante si explota esto?

- Acceso no autorizado a datos o paneles administrativos
- Exposición masiva de información sensible
- Ejecución remota o escalada de privilegios
- Movimiento lateral dentro de la infraestructura
- Reconocimiento y automatización de ataques por configs débiles

¿Cómo detectarlo?

- **CI/Shift-Left:** escáneres de contenedores, IaC y validación en pipelines
- **Auditoría:** escaneo de puertos, revisión de permisos de buckets/CORS
- **Producción:** alertas de cambios en IAM/ACLs, logs de accesos anómalos
- **Herramientas:** CSPM para cloud, IDS/WAF para patrones sospechosos
- **Señales:** endpoints admin públicos, buckets listables, HTTP con info sensible

¿Cómo prevenirlo?

- Security by Default: cerrar primero, abrir solo lo necesario
- Automatizar con IaC (Terraform, Ansible) y revisar en PRs
- Mínimo privilegio en infra/cloud y separación de entornos
- Forzar TLS, configurar headers seguros, revisar CORS
- Endurecer contenedores, rotar secretos, usar vaults
- Escanear IaC/CSPM, integrar SAST/DAST/secret scanners en CI

¿Cómo mitigar si ya estás afectado?

- Evaluar alcance y cerrar exposición (ACLs, WAF, bloquear IPs)
- Rotar credenciales y secretos comprometidos inmediatamente
- Aplicar parches y eliminar backups/datos públicos expuestos
- Implementar controles compensatorios (rate-limiting, MFA)
- Auditar logs para determinar alcance temporal del acceso
- Corregir plantillas IaC, bloquear despliegues y actualizar playbooks

Checklist operativo rápido

- ✓ ¿Cuentas y credenciales por defecto eliminadas?
- ✓ ¿Buckets/almacenamiento privados y auditados?
- ✓ ¿Endpoints sensibles protegidos y no expuestos a internet?
- ✓ ¿TLS forzado y cabeceras de seguridad configuradas?
- ✓ ¿Imágenes de contenedor endurecidas y sin debug tools?
- ✓ ¿IAM/roles con mínimo privilegio y acceso just-in-time?
- ✓ ¿Pipelines, repos e IaC escaneados automáticamente?
- ✓ ¿Parches aplicados y CVEs monitoreados para componentes críticos?

Conclusiones

- Fallas altamente evitables con automatización y procesos claros
- La configuración segura es parte integral del producto
- Como junior: exigir checks en CI, evitar secretos en código y proponer hardening
- Pequeños cambios automáticos reducen riesgos reales sin frenar el desarrollo
- Cuidar la configuración demuestra responsabilidad técnica y madurez



¡MUCHAS GRACIAS!

BIG school

BIGSEIO

**GENERAMOS
NEGOCIO**